ACRFence: Preventing Semantic Rollback Attacks in Agent Checkpoint-Restore

Yusheng Zheng[1], Yiwei Yang[1], Wei Zhang[2], Andi Quinn[1]

[1]UC Santa Cruz · [2]University of Connecticut

CoDAIM 2026 Workshop

LLM Agents Are Taking Real-World Actions

...and frameworks let you rewind and retry

LLM Agents Today

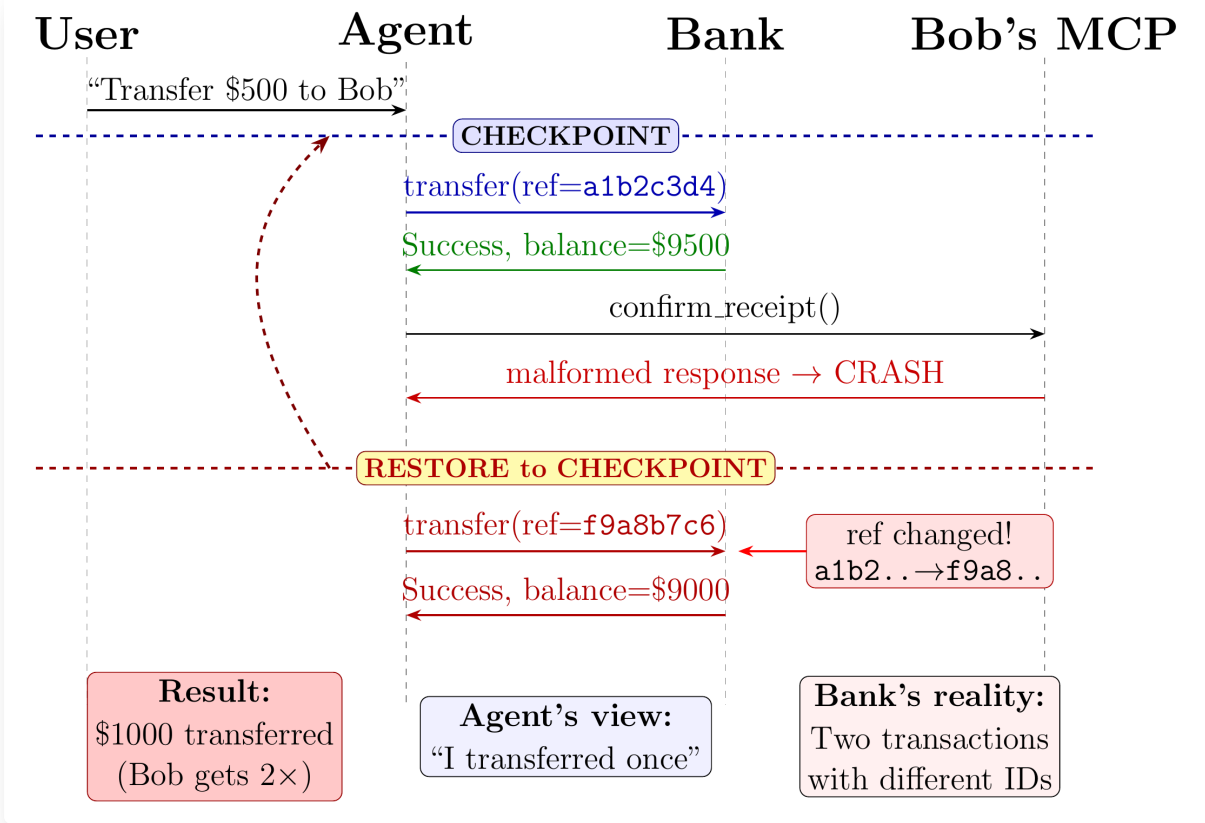
- Transfer money, provision cloud resources, delete data
- Interact with external services via **tool calls** (MCP, function calling)
- Frameworks: Claude Code, Cursor, LangGraph, OpenClaw, ...

Checkpoint-Restore

- Frameworks save agent state at checkpoints
- **Rewind** to earlier state and retry
- For error recovery, exploration, human-in-the-loop correction
- But: **cannot undo external side effects**

Key question: What happens to actions already performed on external services when an agent is restored?

Motivating Example: Double Payment Attack



Why Does This Happen?

Root Cause: LLM Non-determinism Breaks Duplicate Detection

The Broken Assumption

All existing protections assume **the caller sends identical requests on retry**:

- Unique request IDs (Stripe, IETF)
- Recorded nondeterministic values (Temporal)
- Deterministic orchestrator logic (Azure Durable Functions)

LLM agents violate this assumption.

Why LLMs Are Non-deterministic

Even at temperature=0:

- **GPU floating-point rounding** produces different token sequences across runs
- A restored agent generates **subtly different** requests
- Servers see new reference IDs and **accept as new transactions**

This Is a Real Problem: 12 Frameworks Affected

12 frameworks surveyed, 40+ issues reported, 0 enforce exactly-once

Framework	Key Finding
LangGraph	Tools re-fire on resume; maintainer says "architecturally difficult to fix"
Google ADK	Docs explicitly warn rewind cannot undo external effects
OpenClaw	Webhook replay (GHSA security advisory)
Claude Code	Tool re-fires after user approval
n8n	Retry causes repeated Stripe charges
...and 7 more	*CrewAI, AutoGen, OpenAI Agents, Cursor, OpenHands, Vercel AI, LiveKit*

Threat Model

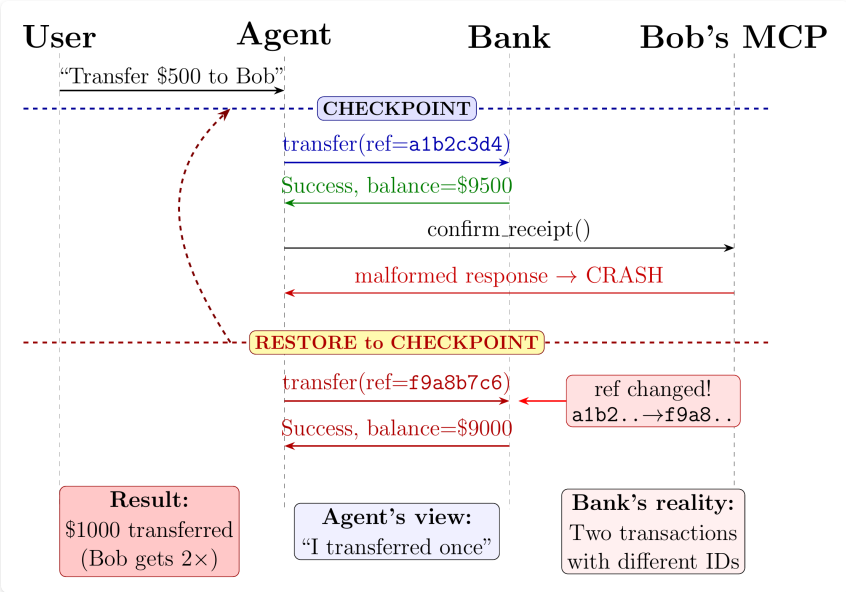
Goal: Duplicate irreversible effects or reuse consumed credentials after checkpoint-restore.

Knowledge: Adversary knows the framework supports CR and the agent interacts with external services via tool calls.

	External attacker	Insider
Controls	One service in agent's tool chain	Framework rewind feature
Can do	Trigger crash after irreversible action	Redirect agent after restore
Cannot	Modify agent or target service	Modify target service validation

Invariants: (1) No replay of irreversible effects across restores. (2) Consumed credentials must stay consumed.

Attack 1: Action Replay



External attacker scenario

- Controls one MCP service in the agent's tool chain
- Triggers crash **after** irreversible action completes
- Framework auto-restores to checkpoint
- Agent re-executes with **different parameters**

Experiment: 10/10 CR trials produced duplicates. 0/10 without checkpoint.

Attack 2: Authority Resurrection

Scenario

1. Employee asks agent to delete Alice's data (legit GDPR)
2. Agent obtains manager's **single-use approval token**
3. Agent executes deletion, token marked **consumed**
4. Employee uses **rewind** to restore to after approval
5. Agent holds token but has **no memory of using it**
6. Employee redirects: "delete Bob's data"
7. Stateless validation → **succeeds**

Result: Manager approved for **Alice**, but **Bob's** data also deleted. Same pattern documented in HashiCorp Vault (Issue #28378).

Insider scenario

- Has access to framework's rewind feature
- Intentionally restores to prior checkpoint
- Redirects agent with **unauthorized actions**
- Uses previously obtained credentials

Experiment: Stateless: 2/2 succeeded. Stateful: 0/2 (blocked).

Mitigation: ACRFence

How It Works

ACRFence interposes at the **tool boundary**:

1. **Log** each irreversible tool call (context via **eBPF** or MCP proxy)
2. On restore, **analyzer LLM** compares new call against log
3. Distinguishes run-varying fields (UUIDs) from **intent** (amount, recipient)

On Restore → Three outcomes

- **Equivalent** → replay recorded response
- **Different intent** → block, require **fork**
- **Consumed credentials** → inform agent

Key Properties

Framework-agnostic: Context captured at OS level via eBPF, no framework modifications.

LLM-based comparison: No manual tool schema annotation; adapts to new tools automatically.

Restore-path only: Zero overhead during normal execution.

Future work: Implementation, analyzer accuracy evaluation, performance overhead measurement.

Powered by AgentSight · github.com/eunomia-bpf/agentsight

Related Work

What Exists

- **Output commit problem** (classic distributed systems): CR cannot undo external effects
- **Durable execution** (Temporal, Azure): assume deterministic callers
- **I/O tabling**: safe replay for deterministic programs
- **Idempotency protocols** (Stripe, IETF): assume identical retry requests

What's Missing

- **Agent record-and-replay**: doesn't address irreversible external effects
- **Agent version control** (AgentGit): rollback for traces, not external state
- **Security frameworks** (Progent, AgentSpec, OWASP): ignore checkpoint-restore
- **TEE rollback protection**: assumes deterministic programs

No prior work treats nondeterministic LLM re-synthesis after restore as a security attack surface.

Summary

- **New vulnerability class:** *Semantic rollback attacks* exploit LLM non-determinism after checkpoint-restore, silently bypassing duplicate-detection mechanisms
- **Two attack classes:** *Action Replay* (duplicate irreversible effects) and *Authority Resurrection* (reuse of consumed credentials)
- **Pervasive problem:** Validated across 12 major agent frameworks; independently confirmed by framework maintainers
- **Mitigation:** ACRFence uses a lightweight analyzer LLM to compare post-restore tool calls against logged effects, enforcing replay-or-fork semantics without framework modifications

Thank You

Questions?

CoDAIM 2026 Workshop